

기후에너지환경부 소관 주요정보통신기반시설 보호지침

제1장 총 칙

제1조 (목적) 이 지침은 「정보통신기반 보호법」 제10조에 따라 기후에너지환경부장관(이하 "장관"이라 한다)이 관할하는 주요정보통신기반시설을 전자적 침해행위로부터 보호하기 위하여 해당 주요정보통신기반시설 관리기관의 장이 준수하여야 할 정보보호에 관한 사항을 정함을 목적으로 한다.

제2조 (용어정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. "정보통신기반시설"이란 국가안전보장·행정·국방·치안·금융·통신·운송·에너지 등의 업무와 관련된 전자적 제어·관리시스템 및 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망을 말한다.
2. "전자적 침해행위"란 정보통신기반시설을 대상으로 해킹, 컴퓨터바이러스, 논리·메일폭탄, 서비스거부 또는 고출력 전자기파 등에 의하여 정보통신기반시설을 공격하는 행위를 말한다.
3. "침해사고"란 전자적 침해행위로 인하여 발생한 사태를 말한다.

제3조 (적용범위) 이 지침은 「정보통신기반 보호법」(이하 "법"이라 한다) 제8조에 따라 장관이 지정한 주요정보통신기반시설을 관리하는 기관(이하 "관리기관"이라 한다)과 해당시설을 관리·운용하는 업무종사자에 적용한다.

제2장 정보보호체계 및 관리

제4조(정보보호책임관) ① 법 제6조제5항에 따른 기후에너지환경부 정보보호책임관은 기후에너지환경부 정책기획관으로 지정하며, 필요한 경우 기후에너지환경부 정보화담당관은 정보보호책임관의 업무 수행을 지원한다.

② 정보보호책임관은 장관이 관할하는 소관분야의 주요정보통신기반시설의 보호에 관한 업무를 총괄한다.

③ 정보보호책임관은 다음 각 호의 업무를 수행한다.

1. 주요정보통신기반시설의 지정 및 지정취소에 관한 업무
2. 주요정보통신기반시설 보호계획의 수립에 관한 업무
3. 주요정보통신기반시설 보호지침의 작성·수정 및 보완에 관한 업무
4. 정보보호 조직·체계의 구축·운영에 관한 업무
5. 취약점 분석·평가 및 침해사고 예방·지원 업무
6. 소용 예산 및 시설·장비 등 자산의 확보에 관한 업무
7. 그 밖에 소관분야 주요정보통신기반시설의 보호를 위하여 필요한 사항

제5조(정보보호책임자) ① 관리기관의 장은 소관 주요정보통신기반시설의 보호 업무를 담당하는 4급 공무원(행정기관) 또는 본부장급 임원(공공기관)을 정보보호책임자로 지정하여야 한다.

② 정보보호책임자는 다음 각 호의 업무를 수행한다.

1. 주요정보통신기반시설의 보호대책 수립·시행
 2. 주요정보통신기반시설 보호업무에 대한 기술적 지원 요청
 3. 취약점 분석·평가 및 침해사고 예방에 관한 업무
 4. 취약점 분석·평가 및 전담반 구성
 5. 주요정보통신기반시설의 보호에 필요한 조치 명령 또는 권고의 이행
 6. 침해사고의 통지
 7. 주요정보통신 기반시설의 복구 및 보호에 필요한 조치
 8. 기타 주요정보통신기반시설의 보호업무에 관한 사항
- ③ 관리기관의 장은 정보보호책임자를 지정하거나 변동사항이 발생한 경우에는 7일 이내에 장관에게 통지하여야 한다.

제6조(정보보호추진체계) ① 장관은 주요정보통신기반시설 보호와 관련된 다음 사항을 협의하기 위하여 협의회를 구성·운영할 수 있다.

1. 주요정보통신기반시설의 지정 및 취소, 지정 범위 조정
 2. 주요정보통신기반시설의 보호계획 및 보호대책 검토
 3. 주요정보통신기반시설 이행점검 및 필요한 조치사항 권고
 4. 그 외 주요정보통신기반시설 보호와 관련하여 협의가 필요한 사항 등
- ② 제1항에 따른 협의회의 장은 기획조정실장으로 하고, 간사는 정보보호책임관으로 하며 위원은 관리기관의 정보보호책임자로 한다. 협의회의 장이 필요하다고 인정하는 경우에는 외부 정보보호전문가를

위원으로 위촉할 수 있다.

제7조(전담 조직의 구성) 관리기관의 장은 제5조제2항에 따른 주요정보통신기반시설 보호 업무를 수행하기 위하여 정보보호책임자 소속 하에 별도의 전담 조직을 구성·운영할 수 있다.

제8조(업무종사자의 준수사항) ① 관리기관의 장은 소관 주요정보통신기반시설을 관리·운용하는 업무종사자(계약직을 포함한다)가 다음 각 호의 사항을 준수하도록 하여야 한다.

1. 주요정보통신기반시설의 보호책임에 관한 사항
2. 비밀유지 및 비밀서약에 관한 사항
3. 주요정보통신기반시설 보호관련 법령 및 지침 등의 준수에 관한 사항
4. 보호관련 지침 및 보호조치 위반에 따른 징계에 관한 사항

② 관리기관의 장은 해당 시설을 관리·운용하는 업무종사자가 보직이 변경되거나 퇴사하는 경우 법 제27조에 따라 소관 주요정보통신기반시설의 관리·운용에 관하여 취득한 비밀을 외부에 유출하지 않도록 주지시켜야 한다. 이 경우 관리기관의 장은 보직이 변경되거나 퇴사하는 자에 대하여 비밀유지에 관한 서약서를 작성하도록 요구할 수 있다.

제9조(보호업무 등의 위탁) 관리기관의 장은 소관 주요정보통신기반시설의 관리·운용 또는 취약점 분석·평가 등 보호에 관한 업무를 전문기관 또는 업체에 위탁하는 경우에는 해당 기관 또는 업체의 위탁업무

종사자에게 법 제27조에 따른 비밀유지의무를 준수하도록 비밀유지
서약서의 작성 요구, 업무관련 기록·자료의 안전한 보존 및 폐기 명
령 등 필요한 조치를 하여야 한다.

제10조(관리기관간 협조) 관리기관의 장은 소관 주요정보통신기반시설
의 보호를 위하여 기후에너지환경부 소관 다른 관리기관과 다음 각 호
의 사항에 관하여 상호 협조할 수 있다.

1. 주요정보통신기반시설의 보호와 관련된 정보의 공유
2. 침해사고 예방·대응 및 복구를 위한 상호협력 및 지원
3. 취약점 및 침해요인과 관련된 정보의 공유
4. 그 밖에 주요정보통신기반시설의 보호를 위하여 상호협력이 필요한
사항

제11조(정보보호 교육·훈련) ① 관리기관의 장은 소관 주요정보통신
기반시설을 관리·운영하는 업무종사자를 대상으로 해당 시설의 보호
를 위하여 필요한 교육·훈련을 연 1회 이상 실시하여야 한다. 다만,
소관 주요정보통신기반시설의 보호에 관한 중요한 절차 및 방법 등의
변경이 있거나 신규로 직원을 채용한 때에는 지체 없이 필요한 교육·
훈련을 실시하여야 한다.

② 관리기관의 장은 외부의 정보보호관련 전문기관에 제1항에 따른
교육·훈련을 위탁하여 실시할 수 있다.

③ 관리기관의 장은 제1항에 따른 교육·훈련을 실시하기 위하여 다
음 각 호의 사항을 정하여야 한다.

1. 교육·훈련의 내용 및 방법
2. 교육·훈련에 관한 기록유지 및 인사관리에 관한 사항
3. 그 밖에 교육·훈련을 위하여 필요한 사항

제3장 정보보호대책 수립·이행

제12조(보호대책 수립) ① 관리기관의 장은 법 제5조제1항에 따라 보호대책을 수립하여 매년 8월말까지 장관에게 제출하여야 한다.

② 관리기관의 장은 보호대책을 수립할 때에는 시행령 제10조제2항에 따라 장관으로부터 통보받은 보호대책 수립지침을 준수하여야 하며, 법 제9조에 따라 실시한 취약점 분석·평가 결과를 반영하여야 한다.

③ 장관은 관리기관으로 하여금 제1항에 따른 보호대책 제출 시 취약점 분석·평가 결과를 함께 제출하도록 할 수 있다.

④ 장관은 취약점 분석·평가 결과 등을 고려하여 필요할 경우 관리기관의 장에게 보호대책을 보완하도록 요청할 수 있다.

제13조(보호대책 이행) ① 장관은 법 제6조 및 시행령 제10조제3항에 따라 정보통신기반보호위원회에서 심의·확정한 기후에너지환경부 소관 보호계획을 관리기관에 통보하여야 한다.

② 관리기관의 장은 제1항에 따라 통보받은 보호계획과 제12조에 따라 수립한 보호대책을 이행하여야 한다.

제14조(이행점검) 장관은 법 제6조에 따른 보호계획을 수립하기 위해 관리기관을 대상으로 보호대책에 대한 이행점검을 실시할 수 있으며

필요시 관리기관으로 하여금 자체 이행점검 후 그 결과를 제출하도록 할 수 있다.

제15조(취약점 분석·평가) ① 관리기관의 장은 법 제9조 및 시행령 제17조 및 제18조에 따라 소관 주요정보통신기반시설에 대한 취약점 분석·평가를 매년 실시해야 한다.

② 관리기관의 장은 취약점 분석·평가를 실시할 때에는 법 제9조제4항의 기준 등을 고려하여 대상, 기간, 절차, 방법 등 필요한 세부 계획을 수립·이행하여야 한다.

③ 관리기관의 장은 법 제9조제3항에 따라 다음 각 호에 해당하는 기관으로 하여금 소관 주요정보통신기반시설의 특성 등을 고려하여 취약점 분석·평가를 하게 할 수 있다.

1. 한국인터넷진흥원
2. 법 제16조에 의한 정보공유·분석센터
3. 정보보호산업의 진흥에 관한 법률 제23조에 따라 지정된 정보보호 전문서비스 기업
4. 한국전자통신연구원

④ 관리기관의 장은 취약점 분석·평가시 발견된 취약점에 대한 조치를 위해 점검항목별 조치 이력 관리대장을 작성·관리하여야 한다.

제16조(자체점검 및 수시점검) ① 관리기관의 장은 시행령 제17조제2항에 따라 취약점 분석·평가가 필요하다고 판단하는 경우에는 평가를 완료한 때로부터 1년이 되지 아니한 때에도 소관 주요정보통신기반시

설에 대한 자체 점검을 실시할 수 있다.

② 관리기관의 장은 다음 각 호의 어느 하나에 해당하는 경우에는 수시로 점검(이하 "수시점검"이라 한다)을 실시할 수 있다.

1. 침해사고의 징후가 있는 경우
2. 시설·장비의 교체 및 보수를 한 경우
3. 침해사고에 따른 복구조치를 한 경우
4. 소관 주요정보통신기반시설의 보호에 관한 절차·방법 및 담당 인력의 변경이 있는 경우

③ 관리기관의 장은 제1항과 제2항에 따른 자체 점검 및 수시점검을 실시할 때에는 다음 각 호의 사항을 고려하여야 한다.

1. 법 제9조에 따른 취약점 분석·평가 기준
2. 취약점 분석·평가의 범위 및 항목, 절차, 방법
3. 이전에 실시한 취약점 분석·평가의 결과

④ 관리기관의 장은 자체 점검 및 수시점검을 실시한 때에는 점검 기간, 대상, 방법 및 결과 등 점검에 관한 제반사항을 기록·관리하여야 한다.

제17조(보완조치) 관리기관의 장은 제15조에 따른 취약점 분석·평가 및 제16조에 따른 점검 결과를 반영하여 다음 각 호의 조치를 하여야 한다.

1. 주요정보통신기반시설 보호를 위해 수립된 각종 보호조치, 절차 및 방법 등의 재검토 및 수정·보완

2. 시설·장비의 개축·보수 또는 설치

3. 그 밖에 취약점 분석·평가 또는 점검 결과를 반영한 보완 조치

제4장 침해사고 예방 및 대응

제18조 삭제

제19조(정보통신망 보안관리) ① 관리기관의 장은 소관 주요정보통신 기반시설 보호를 위하여 타 정보통신망과 분리·운영, 인터넷 연결이 차단된 관리자PC를 통한 시스템 관리기능 접속, 비인가 단말기 접속 차단 등의 기술적 통제수단을 강구하여야 한다.

② 관리기관의 장은 소관 주요정보통신기반시설 관련 서버, 단말기, 네트워크 장비 등에 불필요한 서비스·사용자 계정 등은 제거하고 유지보수를 위한 외부업체의 원격관리를 금지하여야 한다.

③ 관리기관의 장은 소관 주요정보통신기반시설 보호를 위하여 시스템별 사용자접근, 사용내역 등의 로그 자료를 1년 이상 보관하는 등 기록을 유지하여야 한다.

제20조(연락체계의 구축) 관리기관의 장은 소관 주요정보통신기반시설에 대한 전자적 침해사고가 발생한 경우 신속히 대응하고 관계기관에 알리기 위해 필요한 연락체계를 구축하여야 한다.

제21조(침해사고 예방조치) ① 관리기관의 장은 소관 주요정보통신기반시설을 보호하기 위하여 침해사고 예방대책을 수립·시행하는 경우에는 다음 각 호의 사항을 고려하여야 한다.

1. 시스템·네트워크 관리 및 보호에 관한 대책
 2. 정보보호시스템 설치·운용에 관한 대책
 3. 전산자료에 대한 백업조치 등
 4. 악성코드 방지 대책
 5. 접근통제에 관한 대책
 6. 그 밖에 소관 주요정보통신기반시설의 침해사고 예방을 위해 필요한 사항
- ② 제1항에 의한 침해사고 예방조치를 하는 때에는 별표1에서 정하는 사항을 고려하여야 한다.

제22조(침해사고의 통지) ① 관리기관의 장은 침해사고가 발생하여 소관 주요정보통신기반시설이 교란·마비 또는 파괴된 사실을 인지한 때에는 법 제13조제1항에 따라 관계행정기관(국가정보원, 기후에너지 환경부), 수사기관 또는 한국인터넷진흥원에 그 사실을 통지하여야 한다.

② 제1항에 의한 침해사고의 통지에는 다음 각 호의 사항이 포함되어야 한다.

1. 침해사고발생 일시 및 시설
2. 침해사고로 인한 피해내역, 조치현황
3. 기타 신속한 대응·복구를 위하여 필요한 사항

제23조(침해사고 대응조치) ① 관리기관의 임직원 및 유지보수업체의 수탁업무 수행에 참여하는 종사자는 전자적 침해사고의 징후가 있거

나 전자적 침해사고의 발생을 인지한 때에는 이를 즉시 정보보호책임자에게 보고하고 침해사고대응팀 구성 등 필요한 응급조치를 취하여야 한다.

② 정보보호책임자는 소관 주요정보통신기반시설에 대한 중대한 전자적 침해사고의 발생·징후를 보고 받거나 인지한 때에는 이를 국가안보실, 국가정보원, 기후에너지환경부에 즉시 보고하여야 한다. 다만, 관리기관의 장은 소관 주요정보통신기반시설의 교란, 마비 또는 파괴가 일어나지 아니하는 등 경미한 침해사고의 발생·징후는 조치하고 이를 사후 보고할 수 있다.

③ 관리기관의 장은 제1항 및 제2항에 따른 사항을 포함하여 전자적 침해사고 발생에 따른 대응절차 및 방법 등 침해사고 대응체계를 수립하여야 한다. 이 경우 별표 2에서 정하는 사항을 고려하여야 한다.

제24조(침해사고 복구조치) ① 관리기관의 장은 소관 주요정보통신기반시설에 대한 침해사고가 발생한 때에는 해당 정보통신기반시설의 복구 및 보호에 필요한 조치를 신속히 취하여야 한다.

② 관리기관의 장은 제1항의 복구조치를 위하여 필요한 조직, 자원, 외부기관과의 협력 등을 포함하는 복구지원체계를 구축하여야 한다.

③ 관리기관의 장은 제1항 및 제2항의 내용을 포함하여 전자적 침해사고가 발생한 시설에 대한 복구절차 및 방법에 관하여 필요한 사항을 정하여야 한다. 이 경우 별표 2에서 정하는 사항을 고려하여야 한다.

제25조(대응·복구훈련의 실시) ① 관리기관의 장은 임직원 및 유지보

수업체의 수탁업무 수행에 참여하는 종사자가 제23조제3항 및 제24조 제3항에 따른 침해사고 대응·복구에 관한 절차 및 방법을 정확히 숙지할 수 있도록 필요한 훈련을 정기적으로 실시하여야 한다. 이 경우 관리기관의 장이 필요하다고 인정하는 때에는 다른 관리기관과 공동으로 훈련을 실시할 수 있다.

② 관리기관의 장은 대응·복구훈련을 실시한 결과 필요한 경우, 해당되는 대응·복구 절차 및 방법을 수정·보완하여야 한다.

제26조(재검토기한) 기후에너지환경부장관은 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 이 훈령에 대하여 2025년 7월 1일 기준으로 매 3년이 되는 시점(매 3년째의 6월 30일까지를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 해야한다.